

东风奕派微信小程序（商城） 应用安全检测报告

初测

委托单位：东风汽车集团有限公司

测试人员：安全测试组

测试日期：2026 年 07 月 23 日

安全测试组

检测概述

背景介绍

随着国内外网络安全形势日益严峻，攻防不对等拉锯，网络攻击入侵门槛不断拉低，同时网络安全法的落地实施，国家监管层面不断加大信息系统安全监管及处罚力度。一旦信息系统应用软件存在安全漏洞、配置不规范或业务安全风险，易遭受到网络安全攻击，给应用系统的稳定运行、数据安全带来了极大的风险隐患，信息系统的安全已经成为了目前迫切亟待解决的问题。

为进一步加强网络安全管理与数据安全保护，切实防范信息安全风险，依据国家（行业）标准和监管合规要求，对目标系统 微信小程序「东风奕派」（后端 <https://sapp.dfmc.com.cn>、<https://sapp-mall.dfmc.com.cn/appv3/api>）开展应用安全检测，全面识别应用系统面临的安全风险隐患，包含业务安全风险，及时采取相应的技术措施进行安全防范和修复加固，降低攻击入侵，提升业务系统安全健壮性，保障业务系统安全运行。

参考标准

此检测报告引用以下标准与规范（版本于报告编制时经官方来源核对，均为现行有效版本，并结合被测对象所属行业选取相关项）：

- 《OWASP Web Security Testing Guide v4.2》
- 《OWASP Top 10:2025》
- 《PTES 渗透测试执行标准》
- 《ISO/IEC 27001:2022 信息安全管理体系》
- 《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
- 《GB/T 30279-2020 信息安全技术 网络安全漏洞分类分级指南》
- 《GB/T 35273-2020 信息安全技术 个人信息安全规范》
- 《汽车数据安全若干规定（试行）》
- 《中华人民共和国网络安全法》（2025 修正，2026-01-01 施行）
- 《中华人民共和国数据安全法》
- 《中华人民共和国个人信息保护法》

注：上述标准每次执行检测前应重新核对是否有更新版本。

适用说明

针对软件应用（含移动服务端、C/S 服务端等）开展应用安全检测，本次被测对象为 东风奕派微信小程序（商城），不涉及主机、配置等其他检测。

工作原则

开展安全检测应遵循的工作原则是：

（1）规范性原则

安全检测过程有统一的流程，安全检测中使用的方法及使用的文档，需要具有很好的规范性，便于安全检测工作的质量保证，并保证结果的一致性。

（2）可控性原则

安全检测所使用的工具、方法和过程要在双方认可的范围之内，安全检测的进度要符合进度表的安排，保证双方对安全检测的可控性。

（3）整体性原则

安全检测的范围和内容应当系统性、全面，覆盖信息系统安全所涉及的各个层面，并考虑各个层面的相互关系。

（4）最小影响原则

安全检测应尽可能较小的影响网络和系统的正常运行，不能对系统的业务产生显著影响，避免造成被测评系统的性能明显下降、网络拥塞、服务中断等；不删除或修改数据、不触发破坏性操作、不进行高强度爆破、不执行破坏性注入类测试。

（5）保密性原则

对在安全检测中所接触到的用户单位的所有敏感信息，检测人员应遵循相关的保密承诺，不利用相关信息进行任何侵害被检测单位安全利益的行为。本报告不含口令、完整 Cookie、令牌等敏感原文。

检测内容

该检测报告用于应用系统安全检测，可覆盖已上线前安全检测、上线后安全检测、安全评估、互联网安全检测等场景，包含端口安全、基线安全、前端安全、传输安全、身份鉴别、权限管理、会话安全、密钥安全、异常处理、业务安全、日志审计、数据安全、常见漏洞等 13 个大类，共计 55 项安全检测内容。

检测工具

安全检测工具清单如下（当前列举为本次实际使用的主要工具，结合不同应用类型和漏洞组件验证，会使用到其他检测工具）：

工具名称	工具类型	工具用途
浏览器 + 开发者工具	手工检测	页面/前端 JS/请求响应/CORS/HTTP 方法观察取证
前端资源静态分析(webpack chunk 提取)	手工检测	接口枚举、硬编码密钥、签名算法与配置还原
Node.js 自研签名客户端	手工检测	按前端还原的 lgsign 签名构造合法请求验证后端可达性
curl	手工检测	HTTP 请求构造、方法探测与响应头验证

检测声明

安全检测在应用系统上线前开展，如测试环境和生产环境一致，宜使用测试环境开展，如测试和生产差异较大，两套环境应同时开展检测，检测前应确保应用所有组件部署完成，并提供生产和测试环境所有资产信息。

本报告为本次应用安全检测服务的输出结果，供业务方进行漏洞修补和安全加固参考，并进行安全风险规避，安全控制和管理。

本报告的检测结论仅对被测对象当时的状态有效。当检测完成后，由于被测对象的系统变更，本报告不再适用。

在任何情况下，若需引用本报告中的结果或结论都应保持其原有的意义，不得对相关内容擅自进行增加、修改和伪造或掩盖事实。

变更记录

时间	版本	说明	修改人
2026-07-23	V1.0	创建应用安全检测报告（前端静态取证 + 无认证侧实测；认证态业务接口因后端限制微信来源、经隧道不可达，相关项据实标注）	安全测试组

检测结果

检测信息

项目名称	系统级别	应用网址	IP 地址
东风奕派微信小程序（商城）	重要业务系统（车企营销/商城类，按等保三级要求）	微信小程序「东风奕派」（后端 https://sapp.dfmc.com.cn 、https://sapp-mall.dfmc.com.cn/api	27.17.53.126（API 网关，公网）

风险信息

本次安全检测共完成 55 项检测内容，共计发现 7 个安全风险，其中高危风险 3 个、中危风险 4 个、低危风险 0 个（判定为“不符合”）。另有“符合” 7 项、“未测试” 37 项、“不涉及” 4 项。

“未测试” 37 项系因测试条件受限（如缺少对照账号、生产环境非破坏性约束、经隧道无法验证等）无法完成验证，据实标记并说明原因；“不涉及” 4 项系统不涉及对应功能场景。

风险汇总

序号	风险章节	风险名称	风险等级	复测结果
1	3.3.2	前端 JS 泄露安全测试	中	
2	3.4.2	防重放攻击、防篡改功能安全测试	高	
3	3.7.1	Cookie 安全测试	中	
4	3.7.2	CORS 跨域资源共享安全测试	中	
5	3.7.4	会话超时安全测试	中	
6	3.8.1	密钥存储安全测	高	

		试		
7	3.13.16	敏感信息泄露安全测试	高	

注：上表仅列出本次判定为“不符合”的 7 项风险；全部 55 项检测内容的逐项结果（含符合/未测试/不涉及）详见“检测详情”。“复测结果”列供整改复测时填写。

检测详情

端口安全

应用端口服务安全测试

测试编号	PORT-001
风险名称	应用端口服务安全测试
风险等级	中
功能要求	排查应用高危端口可直接访问等风险，如排查应用或服务管理端（包含不限于网络安全设备、云平台、虚拟化平台、大数据平台、邮件管理端、通用类应用管理端等）端口是否限制直接访问、tomcat ajp 协议是否做隔离等风险。 对于三级系统以及重要业务系统，如车联网系统、营销系统等，要求业务端和管理端进行端口分离。 3、对于三级系统以及重要业务系统，如车联网系统、营销系统等，管理端端口应进行 IP/IP 段（范围不易过大）白名单访问限制。
风险影响	攻击者通过高危端口对应用服务开展漏洞利用攻击行为，获取应用服务权限并造成敏感信息泄露
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	未测试
截图说明	端口隔离/管理端口分离/IP 白名单属内网侧配置，经授权隧道无法核验。
修复建议	
备注	

基线安全

应用软件及相关组件版本基线安全测试

测试编号	BASIC-001
风险名称	应用软件及相关组件版本基线安全测试
风险等级	中
功能要求	应用软件开发框架、中间件和其他应用组件等，应满足安全基线要求
风险影响	低版本组件存在安全漏洞，攻击者利用漏洞可获取敏感信息或服务器应用权限
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	未测试
截图说明	组件版本经 webpack 打包混淆，后端仅暴露 Server: nginx（无版本号），无法精确核验组件基线版本。
修复建议	
备注	

前端安全

前端 JS 库软件版本安全测试

测试编号	FRON-001
------	----------

风险名称	前端 JS 库软件版本安全测试
风险等级	中
功能要求	前端应使用满足基线版本的 JavaScript 库版本
风险影响	低版本的 JavaScript 库存在已知安全漏洞，这些漏洞可能允许攻击者在用户浏览网页时执行恶意操作，如窃取用户数据、操纵页面内容、发起跨站脚本攻击 (XSS)、执行服务器端请求伪造 (SSRF)、进行点击劫持或其他形式的攻击手段
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	未测试
截图说明	前端 JS 库经打包混淆，仅识别到埋点 SDK lib_version 4.5.5，未能精确核验各 JS 库版本与已知漏洞对应关系。
修复建议	
备注	

前端 JS 泄露安全测试

测试编号	FRON-002
风险名称	前端 JS 泄露安全测试
风险等级	中
功能要求	前端 JS 文件应不包含敏感信息，如接口、密钥、个人敏感信息、应用敏感信息等
风险影响	前端 JS 文件中的存在敏感信息可能被攻击者探测获取，造成敏感信息泄露。
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	不符合
截图说明	前端 JS 明文包含敏感信息：硬编码的多组应用密钥（小程序/APP 的 appkey 与 appid、微信 AppID、埋点 AppKey，均已脱敏）、约 30 个业务接口路径、可离线还原的请求签名算法，以及源码注释中的内部/测试域名（dev/sit 等）与内网 IP 段（192.168.*/172.26.*）。
修复建议	密钥迁移至服务端/密钥管理服务，前端不下发签名密钥；清理源码注释与调试信息；关键接口鉴权在后端实现，不依赖前端隐藏。
备注	静态确认

传输安全

软件版本信息泄漏安全测试

测试编号	TRAN-001
风险名称	软件版本信息泄漏安全测试
风险等级	中
功能要求	应用服务不应泄露软件版本信息。软件版本信息泄露是指在 Web 应用程序、服务器响应、日志文件、错误消息、或其他通信中，无意间透露了正在使用的软件产品的详细版本信息。
风险影响	如果泄露的版本是一个已知存在严重漏洞的版本，攻击者可以迅速识别出目标系统可能存在的安全隐患，从而更容易发动攻击，获取应用服务权限，产生敏感信息泄露的风险。
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	符合
截图说明	响应头 Server: nginx 未携带版本号，未观察到中间件/开发框架版本信息泄露。
修复建议	
备注	

防重放攻击、防篡改功能安全测试

测试编号	TRAN-002
风险名称	防重放攻击、防篡改功能安全测试
风险等级	高
功能要求	1、请求应具备防重放攻击防护,防止攻击者截取请求,利用重放方式持续进行漏洞探测 2、请求应具备防篡改攻击防护,即对请求包进行签名保护,防止被恶意篡改 3、针对核心系统(如营销、车联网、邮件等系统),集权系统(如监控平台、云平台)和三级及以上系统,应对请求包和响应包双向做防篡改防护,可通过签名、时间戳、随机数等技术措施,防止被恶意篡改 4、针对核心系统(如营销、车联网、邮件等系统),集权系统(如监控平台、云平台)和三级及以上系统,如果存在签名被绕过,应用软件应对隐藏域的参数进行校验
风险影响	攻击者截取请求和响应,利用重放、篡改方式持续进行漏洞探测,可能产生代码执行、权限绕过、敏感信息泄露等各类风险
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不符合
截图说明	业务请求实现了 lgsign 签名 + lgtime 时间戳 + lgnonce 随机数(具备防重放/防篡改设计);但签名密钥与静态盐值硬编码于前端可提取,签名算法可离线复现(已在本地按还原算法构造出合法签名请求),攻击者可离线伪造/篡改签名,对三级车企营销/车联网类系统而言防篡改保护实质失效;服务端 nonce 一次性校验因后端经隧道不可达未能验证。判定为设计性高危(静态确认,非本次实际数据篡改利用)。
修复建议	签名密钥服务端化/一机一密,前端不下发密钥;服务端强制校验时间戳有效窗口与 nonce 一次性;对核心系统实现请求/响应双向防篡改。
备注	设计性风险,非本次实际利用结果

身份鉴别

验证码功能安全测试

测试编号	AUTH-001
风险名称	验证码功能安全测试
风险等级	中
功能要求	1、应用系统登录认证(包含应用后台管理)应包含图形码验证功能。考虑用户体验,可弹性使用图形码(例如首次验证不使用图形码,在验证失败后,再辅助图形码进行验证)或滑块验证等 2、验证码应在服务后端进行验证 3、完善验证码检验机制,避免空参数绕过 4、每次进行登录认证,无论认证是否成功,验证码都应自动刷新 5、三级应用系统应使用双因素认证加随机验证码
风险影响	存在账密爆破风险,攻击者破解窃取应用账号,导致应用敏感信息泄露
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	未测试
截图说明	图形/短信验证码校验流程后端不可达,无法验证。
修复建议	
备注	

账号注册、密码找回及改密功能安全测试

测试编号	AUTH-002
风险名称	账号注册、密码找回及改密功能安全测试

风险等级	中
功能要求	1、应通过管理员在后台进行账号开通（集成 IAM 系统，可通过 IAM 改密模块操作），如在账号自行注册的场景里，要有复杂验证码或其他人机验证功能，防止账号批量注册行为，及账号猜测攻击，包含管理员账号 2、在改密时需要输入原密码进行验证（使用 IAM 模块满足改密要求），并且所有密码信息带*模糊显示，并且改密完成后，应注销会话强制重新登录。 3、修改密码不能为最近 5 次曾使用密码 4、账号注册、账号注销、账号改密、密码找回应记录日志留存
风险影响	存在账号批量注册攻击、账号猜测攻击风险，攻击者破解窃取应用账号，导致应用敏感信息泄露
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	未测试
截图说明	账号注册/改密属微信授权+后端流程，相关端点经隧道不可达，无法验证。
修复建议	
备注	

双因素验证功能安全测试

测试编号	AUTH-003
风险名称	双因素验证功能安全测试
风险等级	中
功能要求	涉及使用短信及邮件模块进行验证，应满足以下安全要求： 1、每个账号只允许每隔 60s 发送一次短信、邮件验证信息 2、每个账号发送短信、邮件验证信息在 120s 有效 3、每个账号发送短信、邮件验证码要求不小于 6 位，其中邮件通过链接验证，需在链接中添加临时 token 进行验证，临时 token 有效期在 30min 内 4、每个账号每日发送短信、邮件验证信息最多不超过 10 次 5、短信、邮件验证码一次性有效（即使用完后失效） 6、短信、邮件验证码应后台发送，不能直接通过响应包直接返回用户 7、业务系统应接入 IAM，并开启双因素验证（面向 C 端由安全主任审核通过可例外）
风险影响	存在短信轰炸、资源枯竭、验证码预测与复用的攻击风险，攻击者通过不断重放短信及邮件发生请求，进行短信及邮件炸弹攻击，消耗服务器资源，影响用户体验
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	未测试
截图说明	短信/双因素验证流程后端不可达；按最小影响原则未做短信轰炸等侵入性验证。
修复建议	
备注	

首次登录强制改密安全测试

测试编号	AUTH-004
风险名称	首次登录强制改密安全测试
风险等级	中
功能要求	1、用户使用初始化密码（包括管理员分配的密码）在进行首次登录时，应用应强制要求用户修改密码，密码长度一般不应小于 8 个字符且应包含大小写字母、数字和特殊字符中的至少三种。 2、对于三级系统，如果初始账号长时间未登录（建议在 1 个月内），应采取账号自动锁定措施，并记录日志
风险影响	存在数据泄露风险。应用可能出现大量账号使用同一初始密码，攻击者可以通

	过社工等手段获取初始密码后导致数据泄露。
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不涉及
截图说明	无管理员分配初始口令的机制（微信授权登录），不涉及首次登录强制改密。
修复建议	
备注	

身份验证失败处理安全测试

测试编号	AUTH-005
风险名称	身份验证失败处理安全测试
风险等级	中
功能要求	系统登录失败提示语句因进行统一模糊说明
风险影响	存在应用敏感信息泄露风险，系统登录失败提示语句不一致，攻击者通过提示语句进行账密爆破，破解窃取应用账号从而导致应用敏感信息泄露
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	未测试
截图说明	登录失败提示一致性需认证态交互，后端经隧道不可达。
修复建议	
备注	

账号多次失败登录锁定安全测试

测试编号	AUTH-006
风险名称	账号多次失败登录锁定安全测试
风险等级	中
功能要求	1、应用应设置账号多次登录失败锁定账号，并且锁定账号在一定时间内自动解锁 2、三级系统应在 5 次输错图形码情况下，也应联动锁定账号，并且锁定账号在一定时间内自动解锁 3、在 3.5.3 相关措施无法有效落实的情况下，对超过 10 次发送短信或邮件验证信息，应联动锁定账号，并且锁定账号在一定时间内自动解锁
风险影响	存在账密爆破风险，攻击者破解窃取应用账号，导致应用敏感信息泄露
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	未测试
截图说明	账号多次失败锁定需认证态多次触发，后端不可达，且避免锁定真实用户账号。
修复建议	
备注	

登录密码禁止明文展示安全测试

测试编号	AUTH-007
风险名称	登录密码禁止明文展示安全测试
风险等级	中
功能要求	在登录界面、改密界面、账号注册等场景下，输入密码时应禁止使用明文显示，可允许短时间明文查看密码，或明文查看部分密码位数
风险影响	存在账密泄露风险，攻击者可以通过恶意软件远程录屏截图等手段获取账号密码，导致应用敏感信息泄露
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不涉及
截图说明	该商城采用手机号 OTP+微信授权登录，无密码明文输入场景。

修复建议	
备注	

强密码策略安全测试

测试编号	AUTH-008
风险名称	强密码策略安全测试
风险等级	中
功能要求	1、系统应具备足够强度的密码策略，要求密码长度不小于 8 位，且应包含大小写字母、数字和特殊字符中的至少三种 2、三级系统应具备伪强密码检测模块
风险影响	存在敏感信息泄露风险，用户使用如 123456 等弱口令密码，这类密码极易被攻击者猜测破解从而获取应用账号权限，导致应用敏感信息泄露
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	未测试
截图说明	采用手机号+微信授权登录，无传统口令强度策略面可测，且后端不可达。
修复建议	
备注	

长期不登录账号锁定安全测试

测试编号	AUTH-009
风险名称	长期不登录账号锁定安全测试
风险等级	中
功能要求	应用账号半年不登录自动锁定
风险影响	存在应用敏感信息泄露风险，应用可能出现不再使用却仍保有高度权限的幽灵账号，由于没有人定期更新该类账号的密码，账号可能会被攻击者破解窃取，导致应用敏感信息泄露
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	未测试
截图说明	半年不登录自动锁定属时间相关+后台策略，无法核验。
修复建议	
备注	

用户标识、角色标识安全测试

测试编号	AUTH-010
风险名称	用户标识、角色标识安全测试
风险等级	中
功能要求	不应在传输过程中带用户标识（如userid、供应商id）、角色标识，应通过cookie、token进行交互验证，userid、供应商id在后端和对应cookie、token进行关联授权 若有传输需要，项目组须提供必要性说明。
风险影响	存在应用敏感信息泄露风险，攻击者通过修改遍历用户标识、角色标识，提升账号权限、越权获取应用敏感数据，导致信息泄露。
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	未测试
截图说明	业务请求参数是否携带userid/角色标识，因业务接口经隧道不可达无法取证；令牌(JWT) sub 含用户ID，由服务端签发。
修复建议	
备注	

权限管理

权限控制功能安全测试

测试编号	PER-001
风险名称	权限控制功能安全测试
风险等级	中
功能要求	1、系统应具备账号赋权功能，可控制任意账户可以访问与操作的资源 2、系统至少具备管理员账户、普通账户两类角色，该两类角色权限应分开 3、管理员应具备对账号进行冻结（锁定）功能，在用户登录、操作异常或被攻击成功等场景下，可直接对账号进行冻结 4、具备操作审计和监控功能，以便及时发现和追踪管理员的恶意操作。
风险影响	存在权限滥用与恶意操作风险，管理员权限过大时，容易引发权限滥用的问题，如随意修改系统配置、删除重要数据等； 存在敏感信息泄露风险，管理员用户没有账号冻结功能，可能导致发生账号泄露事件时，不能及时冻结账号止损。
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	未测试
截图说明	C端商城无管理端角色面暴露，后端不可达，无法核验权限控制/账号冻结/操作审计。
修复建议	
备注	

防越权安全测试

测试编号	PER-002
风险名称	防越权安全测试
风险等级	高
功能要求	系统应具备更严格的权限管理，防止出现越权问题
风险影响	存在未授权访问与越权操作风险，攻击者利用应用权限管理漏洞，提升账号权限、越权获取应用敏感数据，导致信息泄露。
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	未测试
截图说明	越权/IDOR/水平越权为本次重点，但生产后端对隧道来源请求一律返回502/504（仅接受微信网络出口的请求），即便持有效用户令牌与正确 lgsign 签名，也无法调通任一业务接口，故无法在授权隧道侧执行对象级/功能级越权验证。建议在微信真机/开发者工具环境内补测。
修复建议	
备注	受后端网络来源限制，隧道侧不可达

会话安全

Cookie 安全测试

测试编号	SESS-001
风险名称	Cookie 安全测试
风险等级	中
功能要求	Cookie 应启用 Secure 标识以及 HttpOnly 标识 如果一个 Cookie 缺少 Secure 标识，则浏览器允许它通过非加密的 HTTP 连接发送，这意味着这些信息可能以明文形式在网络中传输，增加了数据泄露的风险。攻击者一旦截获，可能冒充用户身份，进行非法操作，如账户接管、数据篡改等。设置附加的 secure 标识来提示浏览器只能通过 Https 来传输 cookie HttpOnly 标识可以阻止浏览器将 Cookie 暴露给客户端脚本（如

	JavaScript)。没有此标识的 Cookie 在遭受 XSS 攻击时，攻击者可以通过注入恶意脚本访问到这些 Cookie。一旦攻击者获取到包含会话标识或其他敏感信息的 Cookie，可以冒充用户进行未经授权的操作，如账户劫持、数据窃取等
风险影响	1、存在数据篡改的风险，如果 Cookie 缺少 Secure 标识，则浏览器允许它通过非加密的 HTTP 连接发送，攻击者可以截获 Cookie，冒充用户身份，进行非法操作，如账户接管、数据篡改等 2、存在数据泄露的风险，如果 Cookie 缺少 HttpOnly 标识，在遭受 XSS 攻击时，攻击者可以通过注入恶意脚本访问到这些 Cookie，可以冒充用户进行未经授权的操作，如账户劫持、数据窃取等
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不符合
截图说明	应用前置网关(sapp.dfmc.com.cn)下发的跟踪 Cookie `mid` 缺少 Secure/HttpOnly/SameSite 标识，且 Cookie 域设为父域、过期时间超长；各网关响应普遍缺失 HSTS/CSP/X-Frame-Options/X-Content-Type-Options/Referrer-Policy 等安全响应头。
修复建议	Cookie 增加 Secure/HttpOnly/SameSite，收敛作用域与有效期；在网关统一补齐安全响应头。
备注	无认证侧实测

CORS 跨域资源共享安全测试

测试编号	SESS-002
风险名称	CORS 跨域资源共享安全测试
风险等级	中
功能要求	系统应正确配置 CORS，避免出现 CORS（跨域资源共享）源验证失败问题
风险影响	错误的 CORS 配置会导致数据泄露、未授权的资源访问等风险，安全问题如下： 1、恶意跨域请求，即便页面只允许来自某个信任网站的请求，但是它也会收到大量来自其他域的跨域请求。这些请求有时可能会被用于执行应用层面的 DDOS 攻击，并不应该被应用来处理 2、内部信息泄漏，假定一个内部站点开启了 CORS，如果内部网络的用户访问该内部站点的同时也访问了恶意网站，恶意网站可以通过 CORS（跨域请求）来获取到内部站点的内容 3、成功利用 CORS 错误配置的影响还包括：操纵或窃取受害者的 cookie，创建和执行无效请求，在易受攻击的 web 服务器中执行恶意代码，接触敏感信息，安装恶意软件，跨站点脚本攻击等 为了有效防范 CORS 跨域资源共享漏洞，应用应遵循以下要求： 1、关闭非正式开启的 CORS 2、白名单限制：定义“源”的白名单，避免使用正则表达式，不要配置 Access-Control-Allow-Origin 为通配符*或 null，严格校验来自请求数据包中 Origin 的值 3、避免将 Access-Control-Allow-Credentials 标头设置为 true，跨域请求若不存在必要的凭证数据，就根据实际情况将其设置为 false
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不符合
截图说明	网关(sapp-mall)CORS 预检返回 Access-Control-Allow-Origin: * 且同时 Access-Control-Allow-Credentials: true, Allow-Headers/Allow-Methods 均为 *, 属过宽配置（通配来源+携带凭证的危险组合）。
修复建议	采用来源白名单，避免通配 *；如无需携带凭证则关闭 Allow-Credentials；收敛允许的方法与头。
备注	无认证侧实测

会话登出功能安全测试

测试编号	SESS-003
风险名称	会话登出功能安全测试
风险等级	中
功能要求	系统功能应经过登录认证后才能访问，退出登录后会话应立即销毁
风险影响	退出登录后服务端未销毁会话，攻击者可复用登出前的会话凭据继续访问受保护功能，导致会话劫持与越权访问。
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	未测试
截图说明	登出后会话是否立即失效需认证态接口比对，后端不可达。
修复建议	
备注	

会话超时安全测试

测试编号	SESS-004
风险名称	会话超时安全测试
风险等级	中
功能要求	所有应用程序应实现会话空闲超时机制。这种超时时间定义为会话在没有用户活动下维持激活状态的一段时间，即在上次最后收到的该会话 ID 的 HTTP 请求之后经过一段预设的时间后结束并销毁会话的机制。建议设置为 30min 超时
风险影响	设备长期登录账号可能出现账号泄露风险
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不符合
截图说明	业务令牌(JWT)签发有效期约 2 年（iat 与 exp 相差约 730 天），远超 30 分钟空闲超时建议，且未见空闲超时机制。
修复建议	缩短访问令牌有效期，引入刷新令牌与空闲超时/滑动过期机制。
备注	令牌载荷已脱敏观察

会话标识安全测试

测试编号	SESS-005
风险名称	会话标识安全测试
风险等级	中
功能要求	1、会话标识应具备唯一性和随机性。 2、会话标识应从一个可信系统，如在应用服务端创建，而不是在客户端创建。
风险影响	存在敏感信息泄露风险，攻击者猜测破解会话标识从而获取应用账号权限，导致应用敏感信息泄露
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	会话令牌为服务端签发的 RS256 签名 JWT，sub 为用户唯一标识，具唯一性且由可信服务端创建。
修复建议	
备注	

会话固定安全测试

测试编号	SESS-006
风险名称	会话固定安全测试
风险等级	中
功能要求	在用户提供的认证信息（如用户名和密码）、相应的权限级别发生变化时，服务器端应重新生成新会话标识，并强制失效之前的旧会话标识。

风险影响	存在敏感信息泄露风险，攻击者利用应用软件在服务器的会话标识固定不变机制，借助他人用相同的会话标识获取认证和授权，然后利用该会话标识劫持他人的会话以成功冒充他人，导致应用敏感信息泄露。
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	未测试
截图说明	身份/权限变更后是否重签会话需可重复登录对比，微信授权登录无法自助复现。
修复建议	
备注	

密钥安全

密钥存储安全测试

测试编号	Key-001
风险名称	密钥存储安全测试
风险等级	高
功能要求	密钥应禁止在代码中明文存储，应进行加密保护或通过环境变量调用
风险影响	一旦代码被泄露（例如通过版本控制系统、代码共享平台或恶意窃取），攻击者可以直接获取密钥，进而解密敏感数据，导致数据泄露。
测试依据	《ISO/IEC 27001:2022 信息安全管理体​​系》
测试结果	不符合
截图说明	前端 JS 明文硬编码多组应用密钥（小程序/APP 的 appkey 与 appid、微信 AppID、埋点 SDK AppKey，均已脱敏），且请求签名所需密钥与静态盐值均在客户端，违反“密钥禁止代码明文存储”。
修复建议	密钥迁移至服务端/密钥管理服务(KMS)，前端不下发签名密钥；采用服务端签名或一机一密方案；轮换已暴露密钥。
备注	静态确认

AK/SK 专项安全测试

测试编号	Key-002
风险名称	AK/SK 专项安全测试
风险等级	中
功能要求	1、AK/SK 应遵循最小权限原则，按照不同功能模块分配不同权限的 AK/SK，避免使用具备云管理权限的 AK/SK 进行功能模块调用。 2、应记录 AK/SK 调用日志，要求日志内容可以溯源定位发起调用的具体功能模块。
风险影响	1、如果使用具备云管理权限的 AK/SK 进行功能模块调用，一旦该 AK/SK 被泄露或被恶意利用，攻击者可能获得对整个云环境的管理权限，从而对云资源进行未经授权的操作，如删除数据、修改配置、创建新的资源等，导致严重的安全事件。 2、没有记录 AK/SK 调用日志或日志信息不完整，当发生安全事件时，无法快速准确地溯源到发起调用的具体功能模块，增加了安全事件调查的难度和时间成本，可能导致无法及时采取有效的应对措施。
测试依据	《ISO/IEC 27001:2022 信息安全管理体​​系》
测试结果	未测试
截图说明	未在前端资源中发现云平台 AK/SK（仅应用级 appkey）；AK/SK 最小权限与调用日志属后端，无法核验。
修复建议	
备注	

异常处理

应用组件错误信息安全测试

测试编号	INFO-001
风险名称	应用组件错误信息安全测试
风险等级	中
功能要求	系统报错信息应不能输出中间件、开发框架、运行环境、数据库等产生的详细错误信息或业务敏感信息，如：个人信息、IP 信息、密码信息等。
风险影响	存在数据泄露、进一步扩大内网攻击范围等风险，详细的错误信息可能包含关于系统架构、代码逻辑、数据结构、数据库查询、文件路径、环境变量等敏感信息，攻击者可据此寻找潜在的安全漏洞，可能出现应用服务器权限被获取，造成应用敏感信息泄露以及内网横向攻击
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	探测中后端返回 nginx 标准 502/504 页面及通用占位响应，未观察到堆栈、框架、数据库等详细报错或敏感信息外泄。
修复建议	
备注	

业务安全

文件上传安全测试

测试编号	BUS-001
风险名称	文件上传安全测试
风险等级	中
功能要求	文件上传功能应包含以下安全策略： 系统应不存在可以直接部署网页脚本的文件上传功能。 存储上传文件的 Web 应用服务应不存在脚本解析漏洞。 上传文件前应经过有效的身份验证。 文件上传的校验应服务端进行。 文件上传功能应存在有效的后缀白名单限制，且无法被突破。 文件上传的位置应无法通过参数进行指定或操控。 文件上传功能应不存在竞争上传问题。
风险影响	存在数据泄露、内网被进一步扩大范围攻击的风险，攻击者可利用文件上传漏洞远程部署木马，并获取服务器的 Web 执行权限，进而导致服务器的 webshell 被获取，造成应用敏感信息泄露以及内网横向攻击
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	未测试
截图说明	文件上传属写操作且接口经隧道不可达，按最小影响原则未验证。
修复建议	
备注	

文件下载安全测试

测试编号	BUS-002
风险名称	文件下载安全测试
风险等级	中
功能要求	在进行文件下载时，应确保下载权限设计合理（如：未授权下载、可读权限能绕过下载文件、下载非预期目录里文件）
风险影响	文件下载权限设计不当，攻击者可未授权下载或越权读取非预期目录文件，造成敏感数据泄露。

测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	未测试
截图说明	文件下载越权需认证态业务接口，后端不可达。
修复建议	
备注	

多线程条件竞争安全测试

测试编号	BUS-003
风险名称	多线程条件竞争安全测试
风险等级	中
功能要求	应用应不存在多线程竞争条件缺陷。对于业务端条件竞争的防范，一般的方法是设置锁。
风险影响	攻击者利用该漏洞可在积分不足情况执行恶意下单兑换商品。
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	未测试
截图说明	多线程条件竞争属写操作，后端不可达且避免污染生产数据。
修复建议	
备注	

重要数据类型验证安全测试

测试编号	BUS-004
风险名称	重要数据类型验证安全测试
风险等级	高
功能要求	应用业务逻辑功能应不存在数据类型验证缺陷。如将相关业务逻辑功能中的各个关键参数赋值为空值、0、负数值、超大数字、字符串、换行符、制表符、添加符号，以及将相关参数键值删除之后，出现的各类非预期结果。
风险影响	攻击者绕过篡改机制（如：签名、访问源 IP 等），利用应用数据类型验证缺陷，如将积分数值、商品数量、userid、供应商 id 进行删除或篡改，导致获取非预期恶意收益或权限。
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	未测试
截图说明	关键参数（数量/金额/积分/标识）篡改需调通业务接口，后端对隧道不可达。
修复建议	
备注	

业务流程非预期执行安全测试

测试编号	BUS-005
风险名称	业务流程非预期执行安全测试
风险等级	中
功能要求	所在业务流程执行过程中，应具备防护机制来保证其遵循正常流程设计执行，所在的业务流程阶段不能被用户恶意非预期执行。
风险影响	攻击者非预期恶意打乱执行业务流程，可导致恶意。
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	未测试
截图说明	业务流程顺序校验需认证态多接口串联，后端不可达。
修复建议	
备注	

日志审计

基础日志审计功能安全测试

测试编号	AUD-001
风险名称	基础日志审计功能安全测试
风险等级	中
功能要求	1、应用应具备安全审计日志记录功能 2、安全审计日志应无法被修改、删除 3、安全审计日志应提供日志数据统计、查询功能
风险影响	存在安全事件无法定位溯源的风险，缺少安全审计日志，会导致出现安全事件后，不能及时溯源定位问题账号以及问题功能，进而造成更大损失
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	未测试
截图说明	安全审计日志功能属后台，无法从外部核验。
修复建议	
备注	

基础日志审计内容安全测试

测试编号	AUD-002
风险名称	基础日志审计内容安全测试
风险等级	中
功能要求	1、安全审计日志应包含：登录日志、操作日志 （1）登录日志：记录用户登录、登出、及登录结果等，应包含管理员账号，登录日志应包含登录时间、登录 IP、登录账号和登录结果 （2）操作日志：记录用户对功能模块访问及操作信息（如：查看、修改和导出等），访问日志应包含操作事件、操作账号、源 IP、访问接口和操作动作等 2、针对不同业务场景，可能还存在其他日志类型，如账号积分流水日志等
风险影响	缺少安全审计日志或日志信息不全，会导致出现安全事件后，不能有效溯源攻击路径，定位风险影响等
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	未测试
截图说明	日志内容（源 IP/操作动作等）属后台，无法核验。
修复建议	
备注	

基础日志审计存储安全测试

测试编号	AUD-003
风险名称	基础日志审计存储安全测试
风险等级	中
功能要求	安全审计日志存储时间应达到 6 个月或以上
风险影响	存在安全事件无法定位溯源的风险，安全审计日志存储时间较短，会导致出现入侵事件后，无法有效溯源攻击路径，进而造成更大损失
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	未测试
截图说明	日志留存 6 个月属后台存储策略，无法核验。
修复建议	
备注	

数据安全

加密传输安全测试

测试编号	DATA-001
风险名称	加密传输安全测试
风险等级	中
功能要求	应用应对数据通信过程中的敏感数据进行加密，如：汽车业务-车辆行驶轨迹信息、汽车充电网的运行数据、vin 码，出行业务-航班车票信息、特定住宿信息，金融业务-个人收入明细、征信信息、支付标记信息、银行卡号，特定身份信息-身份证件号码。应使用 SHA-256 或更强的加密技术加密传输
风险影响	存在敏感信息泄露风险，数据在传输过程中，如果未经加密，就容易被攻击者截获。这些敏感信息包括但不限于用户个人信息、企业商业机密、金融交易数据等，一旦泄露，将给用户和企业带来重大损失。
测试依据	《中华人民共和国数据安全法》、《中华人民共和国个人信息保护法》
测试结果	未测试
截图说明	站点整体使用 HTTPS（TLS 由授权隧道终止，无法独立核验版本）；业务响应中敏感字段的加密因接口不可达无法取证。
修复建议	
备注	

数据脱敏展示安全测试

测试编号	DATA-002
风险名称	数据脱敏展示安全测试
风险等级	中
功能要求	应用页面敏感信息应默认脱敏显示，如：汽车业务-车辆行驶轨迹信息、汽车充电网的运行数据、vin 码，出行业务-航班车票信息、特定住宿信息，金融业务-个人收入明细、征信信息、支付标记信息、银行卡号，特定身份信息-身份证件号码。可以通过点击“显示详情”按钮进行逐个明文显示。
风险影响	存在敏感信息泄露风险，攻击者可以通过恶意软件远程录屏截图等手段获取敏感信息
测试依据	《中华人民共和国数据安全法》、《中华人民共和国个人信息保护法》
测试结果	未测试
截图说明	令牌中昵称手机号呈掩码显示（182****8104）为正向观察，但认证态商城内页展示脱敏因无法进入内页未全面核验。
修复建议	
备注	

数据导出安全测试

测试编号	DATA-003
风险名称	数据导出安全测试
风险等级	中
功能要求	1、二级系统导出信息包含个人信息，应支持文件加密导出 2、三级系统及三级以上系统数据导出应通过审批流程管控，同时日志记录导出行为，导出信息包含个人信息，应支持文件加密导出
风险影响	可能存在敏感数据泄露风险，攻击者获取应用权限后通过数据导出，获取大量个人信息、重要业务数据，将给用户和企业带来重大损失。
测试依据	《中华人民共和国数据安全法》、《中华人民共和国个人信息保护法》
测试结果	未测试
截图说明	未发现数据导出功能面，且后端不可达。
修复建议	

备注	
----	--

常见漏洞

HTTPS 协议安全测试

测试编号	VULN-001
风险名称	HTTPS 协议安全测试
风险等级	中
功能要求	1、要求使用 https 协议进行加密传输。若 HTTP 协议在传输数据时未进行加密，则所有在网络中传输的信息都是以明文形式存在，任何能够捕获网络流量的中间人都可以轻易读取这些数据，导致信息泄露。 2、要求使用 1.2 或更高版本的 TLS 协议。低版本的 TLS 协议由于设计缺陷、已知漏洞、过时的加密算法支持，它们的安全性已经不足以应对现代威胁，继续使用可能使数据传输面临以下风险： （1）已知漏洞利用：旧版本的 TLS 可能存在已知安全漏洞，如 BEAST、POODLE、LUCKY13 等，攻击者可以利用这些漏洞解密或篡改加密通信 （2）弱加密算法：早期的 TLS 版本可能支持过时或已被破解的加密算法（如 RC4、DES、MD5 等），这些算法提供的加密强度不足以抵抗现代计算能力下的攻击，可能导致数据轻易被破解 （3）缺乏 Perfect Forward Secrecy (PFS)：早期 TLS 版本对 PFS 的支持有限。PFS 旨在即使长期密钥被泄露，也无法追溯解密之前的历史会话。缺乏 PFS 意味着一旦主密钥被破解，所有使用该密钥保护的过去会话都可能被解密 （4）不满足现行安全标准：随着安全标准的更新，如 PCI DSS、NIST 等组织已经要求弃用不安全的 TLS 版本。继续使用可能违反合规要求，导致法律责任或信誉损失 （5）浏览器与操作系统弃用：主流浏览器和操作系统厂商（如 Google、Mozilla、Microsoft 等）已逐渐停止支持不安全的 TLS 版本，用户使用老旧浏览器访问这类网站时可能会遇到警告或无法连接的问题 不安全的 TLS 协议主要包括： TLS 1.0：发布于 1999 年，存在诸多已知漏洞和使用了较弱的加密算法 TLS 1.1：发布于 2006 年，虽然比 TLS 1.0 有所改进，但仍存在一些安全缺陷，如部分加密套件的安全性不足
风险影响	存在信息泄露的风险： 1、未使用 HTTPS 协议，则所有在网络中传输的信息都是以明文形式存在，任何能够捕获网络流量的中间人都可以轻易读取这些数据，导致信息泄露 2、低版本的 TLS 协议由于设计缺陷、过时的加密算法支持，存在已知安全漏洞，如 BEAST、POODLE、LUCKY13 等，攻击者可以利用这些漏洞解密或篡改加密通信
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	未测试
截图说明	经授权隧道终止 TLS，无法独立核验真实 TLS 版本与加密套件；站点整体使用 HTTPS。
修复建议	
备注	

HTTP 请求方法安全测试

测试编号	VULN-002
风险名称	HTTP 请求方法安全测试
风险等级	中
功能要求	要求应用服务使用安全的 http 请求方法，如下请求方法应该被禁止使用：

	PUT:这个方法允许客户端向 web 服务器上传新的文件。攻击者可以利用他来上传恶意文件（比如一个 asp 文件通过调用 cmd.exe 来执行命令），或者简单使用受害者服务器作为文件仓库（若存在业务需要，请说明原因并做好权限控制） DELETE:这个方法允许客户端删除 web 服务器上的一个文件。攻击者能利用他简单直接破坏网站或者实施拒绝服务攻击（若存在业务需要，请说明原因并做好权限控制） CONNECT:这个方法允许客户端使用 web 服务器作为代理 TRACE:这个方法简单返回客户端发送给服务器的所有信息，主要用于调试目的，后被发现能够用于实施 XST 攻击
风险影响	存在信息泄露的风险，不安全的 http 请求方法可能造成传恶意文件上传、XST 攻击等安全问题，攻击者通过上传后门文件窃取服务器权限，造成敏感数据泄露
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	TRACE 方法返回 405（已禁用），OPTIONS 为 CORS 预检 204；未观察到危险方法开放（PUT/DELETE 经隧道连接不稳未获确定响应，未见开放迹象）。
修复建议	
备注	

弱口令安全测试

测试编号	VULN-003
风险名称	弱口令安全测试
风险等级	高
功能要求	系统应具备足够强度的密码策略，要求密码长度不小于 8 位，且应包含大小写字母、数字和特殊字符中的至少三种
风险影响	弱口令漏洞是指用户在设置账户密码时采用了复杂度较低、易于被他人猜测或破解的口令。这种漏洞的存在使得攻击者能够相对容易地获取账户的访问权限，进而可能对系统、应用程序或敏感数据造成未经授权的访问、修改、泄露甚至破坏
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不涉及
截图说明	商城采用手机号 OTP+微信授权登录，无静态口令登录，无弱口令面。
修复建议	
备注	

XSS 安全测试

测试编号	VULN-004
风险名称	XSS 安全测试
风险等级	高
功能要求	XSS 全称为 Cross Site Scripting，为了和 CSS 分开简写为 XSS，中文名为跨站脚本。该漏洞发生在用户端，是指在渲染过程中发生了不在预期过程中的 JavaScript 代码执行。XSS 通常被用于获取 Cookie、以受攻击者的身份进行操作等行为。 为了有效防范 XSS 漏洞，应用应遵循以下要求： 1、输入过滤，避免 XSS 的方法之一主要是将用户输入的内容进行过滤。对所有用户提交内容进行可靠的输入验证，包括对 URL、查询关键字、POST 数据等，仅接受指定长度范围内、采用适当格式、采用所预期的字符的内容提交，对其他的一律过滤（客户端和服务端都要） 2、输出转义，例如：往 HTML 标签之间插入不可信数据的时候，首先要做的就

	是对不可信数据进行 HTML Entity 编码 3、使用 HttpOnly Cookie，将重要的 cookie 标记为 httponly，这样的话当浏览器向 Web 服务器发起请求的时候就会带上 cookie 字段，但是在 js 脚本中却不能访问这个 cookie，这样就避免了 XSS 攻击利用 JavaScript 的 document.cookie 获取 cookie
风险影响	存在对造成用户负面影响的风险，攻击者利用 XSS 漏洞窃取敏感信息，如用户的 cookie、会话令牌等，用于后续的攻击。或篡改页面内容，如插入恶意广告、钓鱼链接等，误导用户。亦或执行恶意操作，如以用户身份进行发帖、转账等恶意行为。造成用户负面影响。
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	未测试
截图说明	反射/存储型 XSS 需调通认证态业务接口回显点，后端对隧道不可达。
修复建议	
备注	

XXE 安全测试

测试编号	VULN-005
风险名称	XXE 安全测试
风险等级	中
功能要求	XXE (XML External Entity Injection, XML 外部实体注入) 漏洞是一种影响解析 XML 文档的应用程序的安全漏洞。此漏洞源于应用程序未能正确或安全地处理 XML 文档中的外部实体引用。 为了有效防范 XXE 漏洞，应用应遵循以下要求： 1、禁用外部实体加载：在解析 XML 时，首先且最重要的是禁止加载外部实体。大多数 XML 解析器都提供了配置选项来禁用此功能。 2、使用安全的解析器配置：确保 XML 解析器以最安全的模式运行，限制对外部 DTD (文档类型定义) 和实体的解析。在可行的情况下，使用那些默认禁用外部实体加载的库或 API。 3、输入验证与过滤：对所有用户提交的 XML 数据进行严格的输入验证，避免非法或恶意的 XML 结构。使用白名单方式验证 XML 结构，只允许预期格式的数据通过。
风险影响	存在数据泄露风险，攻击者利用 XXE 漏洞执行 SSRF 攻击，通过实体指向内部网络或服务的 URI，间接获取内部系统的敏感信息，造成数据泄露
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不涉及
截图说明	业务接口均为 JSON 交互，未见 XML 解析入口，不涉及 XXE。
修复建议	
备注	

CSRF 安全测试

测试编号	VULN-006
风险名称	CSRF 安全测试
风险等级	高
功能要求	CSRF (Cross-Site Request Forgery) 跨站请求伪造，是指攻击者通过构建一个恶意网页，诱使已经登录了目标网站的用户访问这个恶意网页，利用用户的登录状态，在用户不知情的情况下执行攻击者预设的操作。 这种攻击主要是利用了网站对用户身份验证后产生的 cookie 或其他认证信息 (如 JWT Token 等) 在一定有效期内维持用户身份的特性。攻击者并不能获取到这些认证信息，但他们可以诱导已登录的用户发送一个请求到目标站点，而该请求是由攻击者精心构造的，旨在进行非法操作，比如转账、修改密码、发

	布内容等。 为了有效防范 CSRF 漏洞，应用应遵循以下要求：
风险影响	存在应用信息泄露风险，攻击者利用用户的登录状态，在用户不知情的情况下执行攻击者预设的操作，如修改密码、发布内容等，可能造成账号被窃取，应用信息泄露风险。
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	业务鉴权采用 Authorization: Bearer 头 + 请求签名(lgsign)，非纯 Cookie 环境凭证，跨站请求无法自动携带鉴权头，天然缓解 CSRF。
修复建议	
备注	

SSRF 安全测试

测试编号	VULN-007
风险名称	SSRF 安全测试
风险等级	高
功能要求	应用软件应不存在 SSRF 漏洞。SSRF(Server-Side Request Forgery:服务器端请求伪造)是一种由攻击者构造形成由服务端发起请求的一个安全漏洞。SSRF 漏洞主要发生在服务器端，当服务器在处理用户请求时，没有对用户输入的 URL 进行有效的验证和过滤，导致攻击者可以构造恶意的 URL，让服务器发起非预期的请求。这些请求可能指向内部网络，如数据库、文件服务器等，也可能指向外部网络，如其他网站、开放端口等。一旦攻击成功，攻击者可以获取到服务器的敏感信息，甚至可能进一步利用这些信息对内部网络进行攻击。 为了有效防范 SSRF 漏洞，应用应遵循以下要求： 1、输入验证和过滤：对所有用户输入进行严格的验证和过滤，确保输入只包含预期的字符和格式。避免直接拼接用户输入到 URL 或请求中，使用参数化查询或安全的库来处理输入 2、限制请求的目标：限制服务器能够请求的目标地址范围，只允许访问预定的白名单地址。如果需要访问内部资源，确保使用安全的内部接口，并限制访问权限
风险影响	SSRF 漏洞的影响范围广泛，存在的风险包括： 敏感信息泄露：攻击者可以利用 SSRF 漏洞获取数据库、文件服务器等内部资源的敏感信息，如用户数据、配置文件等。 被执行恶意操作：攻击者可以利用 SSRF 漏洞执行恶意操作，如远程命令执行、文件上传等，进一步危害系统的安全。 应用系统无法正常提供服务：攻击者可以利用 SSRF 漏洞对目标服务器发起大量的恶意请求，导致服务器资源耗尽，无法正常提供服务。
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	未测试
截图说明	未发现可达的 URL 获取型接口面，且后端不可达，未验证 SSRF。
修复建议	
备注	

SQL 注入安全测试

测试编号	VULN-008
风险名称	SQL 注入安全测试
风险等级	高
功能要求	SQL 注入是一种常见的网络攻击手法，它利用了 Web 应用程序对用户输入数据处理不当的漏洞，让攻击者能够在数据库查询中插入恶意的 SQL 代码。这种攻击可以让攻击者未经授权地访问、修改或删除数据库中的数据，甚至完全控制数

	数据库服务器。 为了有效防范 SQL 注入漏洞，应用应遵循以下要求： 1、使用 PreparedStatement 或者参数化查询能够有效地防止 SQL 注入 2、对所有用户输入的数据进行转义处理，尤其是对于可能用于分隔字符串或改变 SQL 语句结构的特殊字符（如单引号、双引号、分号、注释符等），将其转换为安全的形式，使其无法被解释为 SQL 命令的一部分 3、对用户的输入进行严格的验证，例如检查输入的数据类型、长度、格式是否符合预期，可以采用白名单方式，只允许特定字符或格式的输入
风险影响	存在被执行恶意操作的风险，成功的 SQL 注入攻击可以从数据库中读取敏感数据、修改数据库数据（插入/更新/删除）、对数据库执行管理操作（例如关闭 DBMS）、将后门文件写入文件系统，在某些情况下，还可以在操作系统执行恶意命令
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	未测试
截图说明	SQL 注入需调通业务接口注入参数，后端对隧道一律 502/504 不可达。
修复建议	
备注	

LDAP 注入安全测试

测试编号	VULN-009
风险名称	LDAP 注入安全测试
风险等级	高
功能要求	LDAP (Lightweight Directory Access Protocol)，轻量级目录访问协议，是一种在线目录访问协议，主要用于目录中资源的搜索和查询。如果在用户可控制的输入中没有对 LDAP 语法进行除去或引用，那么生成的 LDAP 查询可能会导致将这些输入解释为 LDAP 而不是普通用户数据。这可用于修改查询逻辑以绕过安全性检查，或者插入其他用于修改后端数据库的语句，可能包括执行系统命令。 为了有效防范 LDAP 注入漏洞，应用应遵循以下要求： 1. 使用不允许此弱点出现的经过审核的库或框架，或提供更容易避免此弱点的构造。 2. 使用自动实施数据和代码之间的分离的结构化机制。这些机制也许能够自动提供相关引用、编码和验证，而不是依赖于开发者在生成输出的每一处提供此能力。 3. 使用完成必要任务所需的最低特权来运行代码。 4. 如果在有风险的情况下仍需要使用动态生成的查询字符串或命令，建议对参数正确地加引号并将这些参数中的任何特殊字符转义。 5. 使用“接受已知善意”输入验证策略：严格遵守规范的可接受输入的黑名单。拒绝没有严格遵守规范的任何输入，或者将其变换为严格遵守规范的内容。不要完全依赖于通过黑名单检测恶意或格式错误的输入。但是，黑名单可帮助检测潜在攻击，或者确定哪些输入由于格式严重错误而应直接拒绝。
风险影响	存在被执行恶意操作的风险，成功的 LDAP 注入攻击可以从 LDAP 目录树下的数据库中读取敏感数据、修改数据库数据（插入/更新/删除）、对数据库执行管理操作（例如关闭 DBMS）、将后门文件写入文件系统，在某些情况下，还可以在操作系统执行恶意命令
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	未测试
截图说明	未见 LDAP 交互面，后端不可达，未验证。
修复建议	
备注	

文件包含安全测试

测试编号	VULN-010
风险名称	文件包含安全测试
风险等级	中
功能要求	文件包含漏洞是 Web 应用程序中的一种常见安全漏洞，它允许攻击者通过操纵文件包含功能，让应用程序加载并执行了非预期的恶意文件。这种漏洞通常发生在动态网页编程中，当程序设计时为了提高代码复用性，会使用特定的函数或语句（如 PHP 中的 <code>include()</code>，<code>require()</code>，或 JSP 中的 <code><jsp:include></code>）来包含外部文件。如果对外部文件的路径没有进行充分的验证或过滤，攻击者就可以通过精心构造的输入来控制这些包含函数的参数，从而引入恶意代码。 为了有效防范文件包含漏洞，应用应遵循以下要求： 1、严格限制文件包含函数的参数，确保只能从预定义的、安全的目录中包含文件。 2、对用户提交的包含文件请求进行严格的过滤和校验，去除危险字符，如 <code>../</code> 等路径遍历字符，以及不必要的协议头如 <code>http://</code>、<code>ftp://</code> 等
风险影响	存在信息泄露的风险，攻击者通过恶意构造的输入，诱使服务器加载并执行非预期的文件，从而导致远程命令执行、信息泄露
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	未测试
截图说明	未见文件包含参数面，后端不可达。
修复建议	
备注	

反序列化安全测试

测试编号	VULN-011
风险名称	反序列化安全测试
风险等级	高
功能要求	反序列化漏洞是一种安全漏洞，出现在使用序列化和反序列化功能的应用程序中，尤其是在处理来自不可信来源的序列化数据时。序列化是将对象转换为一系列字节（如二进制数据或文本字符串），以便存储或通过网络传输；而反序列化则是将这些字节流还原为原始对象的过程。当应用程序对用户提供的数据执行反序列化操作时，如果缺乏足够的验证和安全控制，恶意攻击者就可能利用特制的序列化数据来执行未经授权的操作。 为了有效防范反序列化漏洞，应用应遵循以下要求： 1、输入验证与数据过滤： 对所有反序列化的输入数据进行严格的验证，确保它们来自可信的源头并且格式正确。实施输入过滤，拒绝不满足预期格式或包含潜在恶意数据的输入。 2、使用白名单： 实施类型白名单，仅允许特定类或类型的对象被反序列化。这样可以阻止恶意对象的创建。 3、禁用不需要的类和库： 评估并禁用任何不必要或可能引入风险的类库，特别是那些具有已知漏洞的类库。 4、限制功能与权限： 运行应用程序在最低权限环境下，确保即使发生反序列化攻击，攻击者也无法执行高权限操作。 5、序列化格式的选择： 使用更安全的序列化格式，如 Protocol Buffers 或 MessagePack，这些格式通常比传统的 Java 序列化更安全，因为它们提供了更细粒度的控制。 6、保持软件及库的更新： 定期更新所有的软件框架和第三方库，以获取最新的安全修复和补丁。 7、安全配置：

	对于像 Fastjson 这样的库，确保遵循其安全配置指南，禁用不安全的功能，如自动类型转换。
风险影响	存在信息系统被远控的风险，攻击者可以通过构造含有恶意指令或数据的序列化字符串，将恶意序列化数据注入到目标应用程序的反序列化流程中，从而实现远程命令执行
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	未测试
截图说明	反序列化需可达业务接口与特定入口，后端不可达。
修复建议	
备注	

远程命令执行安全测试

测试编号	VULN-012
风险名称	远程命令执行安全测试
风险等级	中
功能要求	远程命令执行漏洞（Remote Command Execution，简称 RCE）是一种常见的安全漏洞，它允许攻击者通过向目标系统发送恶意指令，从而远程执行系统命令或代码。 为了有效远程命令执行漏洞，应用应遵循以下要求： 1、严格输入验证：对所有用户输入进行严格的验证，确保输入内容符合预期且不含恶意代码。 2、输入过滤：使用合适的过滤机制，如黑名单（禁止特定字符或模式）和白名单（仅允许特定字符或模式），来过滤和清理用户输入。 3、避免使用危险函数：尽量避免在代码中直接使用能够执行系统命令的函数，如 PHP 中的 exec()，system()，passthru()，shell_exec() 等。 4、最小权限原则：确保应用程序和服务以最小权限运行，即使发生漏洞，攻击者也无法获得过高的权限。
风险影响	攻击者通过向目标系统发送恶意指令，从而远程执行系统命令或代码，可能导致系统被完全控制、数据泄露、服务中断等严重后果。
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	未测试
截图说明	无命令执行入口证据，后端不可达。
修复建议	
备注	

暗链安全测试

测试编号	VULN-013
风险名称	暗链安全测试
风险等级	高
功能要求	暗链，又称为黑链或隐蔽链接（hidden links），是一种常见的网络安全风险。暗链的主要目的是通过非正当手段为攻击者的网站增加外部链接，暗链可能链接到含有恶意软件、钓鱼网站或其他不安全的网站，对访问这些链接的用户构成安全威胁。 为了有效防范暗链，应用应遵循以下要求： 定期检查网站源代码： 定期审查网站的 HTML 源代码，特别是首页和权重较高的页面，查找任何未知或可疑的链接。这包括检查隐藏的 CSS 样式（如 display:none）或与背景颜色相同的文字链接。 保持更新和维护： 保持网站平台、插件、主题和所有软件组件的最新状态，及时安装安全更新和补丁，修复已知漏洞。

	3、备份与恢复计划： 定期备份网站数据和文件，万一遭受攻击，能够迅速恢复到未被篡改的状态。
风险影响	存在信息泄露的风险，被植入恶意链接可能造成用户信息泄露，影响用户体验
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	审查前端 SPA 页面与主 JS，未发现隐藏暗链、display:none 恶意外链或与背景同色的隐蔽链接。
修复建议	
备注	

开发框架、中间件安全测试

测试编号	VULN-014
风险名称	开发框架、中间件安全测试
风险等级	中
功能要求	开发框架与中间件构成了现代应用程序和服务的基石，极大地赋能开发者，提供了高效且便捷的开发解决方案。然而，在实际搭建过程中，由于兼容旧有组件的需求、个人编程习惯偏好等因素，开发团队有时未能采用最新且更为安全的版本。这一现状不幸留下了隐患，使得应用服务中潜藏了已知的历史安全漏洞，增加了被恶意攻击的风险。 为了有效防范开发框架、中间件漏洞，应用应遵循以下要求： 安全性优先：在项目规划初期即纳入安全考量，优先选用具有良好安全记录和支持的组件。 定期更新：定期检查并升级至框架与中间件的最新安全版本，以封堵已知漏洞。 3、安全配置：遵循最佳安全实践，确保框架和中间件的配置是安全的，不要依赖默认配置。
风险影响	存在敏感信息泄露风险，攻击者可利用漏洞获取服务器权限，造成敏感信息泄露
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	未测试
截图说明	后端仅暴露 Server: nginx（无版本），组件经打包混淆无法精确指纹，未确认具体框架/中间件已知漏洞。
修复建议	
备注	

未授权访问安全测试

测试编号	VULN-015
风险名称	未授权访问安全测试
风险等级	高
功能要求	应用软件应不存在常见的未授权访问漏洞，如 Spring Boot Actuator 未授权访问漏洞，Spring Eureka 未授权访问漏洞，MongoDB 未授权访问漏洞，swagger 未授权访问漏洞，Hadoop 未授权访问漏洞等。
风险影响	存在敏感信息泄露风险
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	探测 actuator/swagger/druid/.env/api-docs 等常见未授权路径，均为 SPA 前端兜底（软 200）或通用占位响应，未确认存在真实未授权敏感端点暴露。
修复建议	
备注	

敏感信息泄露安全测试

测试编号	VULN-016
风险名称	敏感信息泄露安全测试
风险等级	高
功能要求	应用软件应不存在下列敏感信息泄露风险 1、源代码泄露：公开暴露的源代码文件（如.php, .jsp, .py, .asp等）可能包含敏感信息，如数据库连接字符串、API 密钥、硬编码凭据等。 2、配置文件泄露：包含敏感配置信息的文件（如.env, config.php, web.config等）被公开，可能泄露数据库凭据、加密密钥、系统设置等。 3、备份文件泄露：未受保护的数据库、系统或网站备份文件可能包含大量敏感数据，如用户信息、交易记录、内部文档等。 4、未授权访问的管理界面：如后台管理面板、控制台等，攻击者可能通过默认或弱口令进入，直接操控系统。 5、默认示例文件泄露：如安装脚本、示例页面、测试数据等，它们可能提供有关系统架构、软件版本或配置的信息，也可能成为攻击入口。
风险影响	存在应用服务敏感信息泄露风险
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不符合
截图说明	前端资源泄露敏感信息：硬编码应用密钥（已脱敏）、约 30 个内部业务接口、请求签名算法与静态盐值、源码注释中的内部/测试域名（dev/sit 等）与内网 IP 段（192.168.*/172.26.*）。
修复建议	前端不下发密钥；清理源码注释与调试信息；关键接口在后端鉴权；轮换已暴露密钥。
备注	静态确认

处理用时安全测试

测试编号	VULN-017
风险名称	处理用时安全测试
风险等级	中
功能要求	应用软件应不存在拒绝服务漏洞，如查询时间更改导致的拒绝服务漏洞、修改尺寸大小造成拒绝服务漏洞、退出登录处存在的拒绝服务漏洞等
风险影响	存在应用软件无法正常提供服务的风险，影响用户体验
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	未测试
截图说明	未执行拒绝服务/处理用时类测试（最小影响原则），且后端不可达。
修复建议	
备注	